

Référence API UniFi Network — UDM Pro Max NVR00 (192.168.11.1)

****Document : référence technique complète et explicite de l'API, établie par tests réels les 22/09/2026 (et relevés du 24-25/08). Version cible : UniFi OS 10.5.67 / Network 10.6.101.****

Légende :  = vérifié par test réel ·  = endpoint existant, non testé ·  = inexistant (404/400) ·  = nécessite accord explicite avant usage (CHANGE)

1. Authentification et transport

1.1 Clé API (méthode utilisée et vérifiée)

...

Header : X-API-Key: <clé>

Base : https://192.168.11.1/proxy/network/

TLS : certificat autosigné -> désactiver la vérification (verify_mode=CERT_NONE)

...

- La clé API se crée dans l'UI : ****Settings → Control Plane → API**** (admin local requis).
- Portée : ****lecture ET écriture**** (POST 201 confirmé  §5). Aucun périmètre restreint observé.
- Stockage local : ``/root/.hermes/credentials/udm_api_key.txt`` (mode 600).
- ****Non authentifié**** : endpoints renvoyant 401 avec ``{"error":{"code":401,"message":"Unauthorized"}}``.

1.2 Session admin (méthode historique, vérifiée le 24/08)

...

POST /api/auth/login {"username":"...", "password":"...", "rememberMe":true}

→ cookie de session + header x-csrf-token (à répéter sur les POST/PUT)

...

- ****/proxy/* exige x-csrf-token**** dérivé du JWT de session (verrou vérifié sur Talk .
- Compte local ``melokane`` (admin local, sans SSO) : mot de passe = celui de l'UI.
- Le token console ``/api/access`` (type Bearer) ****ne passe pas**** sur `/proxy/network`  (401).

1.3 SSH root (canal complémentaire)

...

ssh root@192.168.11.1 (mot de passe = fourni par AdMel, non stocké)

...

Donne : iptables, MongoDB ace (127.0.0.1:27117), état udapi
(`/data/udapi-config/ubios-udapi-server/ubios-udapi-server.state`), moteur DPI
(`/usr/share/dpi/tdts/bwdpi.app.db`). Toute écriture par ce canal = DESTRUCTIVE.

2. Cartographie générale des endpoints

Trois familles d'URLs coexistent sous `https://192.168.11.1/proxy/network/` :

Famille	Modèle	Exemple
--- --- ---		
v1 legacy	`/api/s/{site}/rest/{objet}` — CRUD list-based	`rest/usergroup`
v1 cmd/stat	`/api/s/{site}/cmd/...`, `/api/s/{site}/stat/...`	`stat/sta`
v2 Policy Engine	`/v2/api/site/{site}/{objet}` — validation Spring stricte	`firewall-policies`

Site par défaut : `default` (id `58ae8e3f10bed9fc2dd82fcb`).

3. Endpoints v2 Policy Engine (vérifiés sauf mention)

3.1 Firewall policies — LE cœur

...

GET	/v2/api/site/default/firewall-policies	 200 — liste complète
POST	/v2/api/site/default/firewall-policies	  201 (testé puis rollbacké)
GET	/v2/api/site/default/firewall-policies/{id}	 (non testé)
PUT	/v2/api/site/default/firewall-policies/{id}	 (non testé)
DELETE	/v2/api/site/default/firewall-policies/{id}	  204 (testé sur objet dédié)

...

Réponse GET (162 politiques chez nous) : tableau d'objets :

```
``json
{
  "_id": "6a9c69117064e9f2d0899b07",
  "name": "QUARANTAINE → tout bloqué (interne + WAN)",
  "action": "BLOCK",           // ALLOW | BLOCK | REJECT
  "enabled": true,
  "ip_version": "IPV4",       // IPV4 | IPV6
  "protocol": "all",          // all | tcp | udp | icmp | ...
  "connection_state_type": "ALL", // ALL | CUSTOM
  "connection_states": [],    // NEW | ESTABLISHED | RELATED | INVALID
}
```

```

"create_allow_respond": false,
"logging": false,
"index": 10012,                // ordre d'évaluation
"predefined": false,
"match_ip_sec": false,
"schedule": {"mode": "ALWAYS", "repeat_on_days": [], "time_all_day": false},
"source": {
  "zone_id": "677352e0cb23f3310c514af9",
  "matching_target": "IP",      // IP | ANY | CLIENT | CLIENT_GROUP | ...
  "matching_target_type": "SPECIFIC",
  "ips": ["192.168.99.0/24", "192.168.11.251/32"],
  "match_mac": false,
  "match_opposite_ips": false
},
"destination": {"zone_id": "...", "matching_target": "ANY", "port_matching_type": "ANY"},
"hits": 123, "last_hit": 1790000000 // compteurs réels
}
...

```

****Contraintes de validation (découvertes par erreur 400 )** :**

- `schedule` ****obligatoire**** (sinon 400 NotNull.schedule)
- `create\_allow\_respond` ****interdit sur une création BLOCK****
(400 `api.err.FirewallPolicyCreateRespondTrafficPolicyNotAllowed`) → toujours `false` au POST
- payload minimal valide pour POST :

```

```json
{
 "name": "...", "enabled": false, "action": "BLOCK",
 "ip_version": "IPV4", "protocol": "all",
 "connection_state_type": "ALL", "connection_states": [],
 "create_allow_respond": false, "logging": false,
 "icmp_typename": "ANY", "icmp_v6_typename": "ANY",
 "schedule": {"mode": "ALWAYS", "repeat_on_days": [], "time_all_day": false},
 "source": {"zone_id": "<zone>", "matching_target": "IP", "matching_target_type": "SPECIFIC",
 "ips": ["192.168.22.200/32"], "match_opposite_ips": false, "match_mac": false},
 "destination": {"zone_id": "<zone>", "matching_target": "ANY",
 "port_matching_type": "ANY", "match_opposite_ports": false}
}
...

```

**\*\*Filtre applicatif\*\*** (présent sur 24 politiques existantes , POST non testé) :  
les politiques portent des critères `app` (catégories/applications DPI) — cf. §7.

### ### 3.2 Autres endpoints v2

Endpoint	Verbe	État	Contenu
`/v2/api/site/default/zone-matrix`	GET	✓ 200 (1er appel)	matrice de zones ; capricieux au 2e appel (HTML)
`/v2/api/site/default/qos-rules`	GET	✓ 200	règles QoS du gateway (34 Ko)
`/v2/api/site/default/traffic-flows`	**POST**	✓ 200	**flux par domaine** : domain, ip, port, region, zone, direction, duration, action (allowed/blocked). POST avec `{}` ou fenêtre `{ "start": epoch, "end": epoch, "type": "all" }
`/v2/api/site/default/firewall-policies`	GET/POST/DELETE	✓	cf. §3.1
`/v2/api/site/default/firewallpolicy` (singulier)	GET	✗ 404	**ne pas utiliser** — cause du faux diagnostic du 22/09 matin
`/v2/api/site/default/traffic-rules`, `zones`, `alarms`, `events`, `webhooks`, `settings`	GET	✗ 404	noms inexacts
`/v2/api/site/default/traffic-flows`	GET	405	méthode POST uniquement

---

### ## 4. Endpoints v1 (api/s/default) — vérifiés ✓

#### ### 4.1 rest/\* — CRUD standard

Objet	Verbes	État	Notes
`rest/usergroup`	GET	✓ 200	15 groupes ; champs `qos_rate_max_up/down` en Mbps, **1 = illimité**
	POST	✓ 200	**pattern de validation** : `-1 [2-9] [1-9][0-9]{1,4} 100000` → **1 Mbps impossible**, min 2
	DELETE	✓ 200	(objet de test créé puis supprimé)
	PUT	⚠	même modèle
`rest/user`	GET	✓ 200	23 044 clients connus ; champ `usergroup_id`
	PUT	⚠	bascule de groupe : `PUT rest/user/{id} {"usergroup_id": "<id>"}`
	PUT	⚠	blocage : `PUT rest/user/{id} {"blocked": true}`
`rest/networkconf`	GET	✓ 200	27 réseaux (VLAN 1-30 + 99 QUARANTAINE + 22 LAB-IoT)
`rest/wlangroup`	GET	✓ 200	groupes WLAN
`rest/portconf`	GET	✓ 200	profils de ports switch
`rest/dpigroup`	GET	✓ 200	groupes DPI
`rest/routing`, `rest/firewallgroup`, `rest/dynamicdns`, `rest/scheduletask`	GET	✓ 200	(scheduletask = tâches planifiées contrôleur)
`rest/setting`	GET	✓ 200	⚠ **retourne la config SMTP avec `x_password` en clair** (F6)
`rest/hotspotconf`, `rest/portforwarding`, `rest/snmp`, `rest/tag`	GET	✗ 400	InvalidObject (exposition autre part)

### ### 4.2 stat/\* — capteurs

Endpoint	État	Contenu
`stat/sta`	 200	clients actifs : `mac`, `hostname`, `ip`, `vlan`, `usergroup\_id`,
`\*\*rx\_bytes`/`tx\_bytes` cumulés\*\*, `rx\_bytes-r`/`tx\_bytes-r` (taux o/s), `assoc\_time`, `uptime`,		
`idletime`, `blocked`		
`stat/alluser`	 200	tous clients connus (23 044), `last\_seen`, `is\_guest`
`stat/health`	 200	santé sous-systèmes
`stat/dpi`	 200	état DPI
`stat/report/daily.user`	 200	historique journalier \*\*par MAC\*\* (263 Ko de données)
`stat/report/hourly.user`	 200	identités seulement, \*\*pas les octets\*\* (limite confirmée 24/08)
`stat/alarm`, `stat/event`	 404	supprimés en 10.x — collections Mongo `alarm`/`event` vides ; restent `trigger\_log`, `admin\_activity\_log` (SSH : `mongo 127.0.0.1:27117/ace`)

### ### 4.3 cmd/\* — actions ( non testées, modèles connus)

...

```
POST /api/s/default/cmd/stamgr {"cmd":"disconnect-sta","mac":"AA:BB:CC:DD:EE:FF"}
POST /api/s/default/cmd/sitemgr {"cmd":"kick-sta","mac":"..."}
```

...

Le 22/09 : `cmd` en GET → 404 (normal, POST only). POST non testé .

---

## ## 5. Modèles de données clés

### ### 5.1 Groupes QoS (actionneur de bridage)

```
```json
{"name": "QUARANTAINE", "qos_rate_max_up": 2, "qos_rate_max_down": 2,
 "site_id": "58ae8e3f10bed9fc2dd82fcb"}
```
```

- 15 groupes réels, dont : `touss` 2/2 · `QUARANTAINE` 2/2 · `normal` 1000/2000 ·  
`Myadmin` -1/-1 (jamais bridé) · `Default` 10/8
- \*\*Plage légale\*\* : 2 → 100 000 Mbps, ou -1 (illimité). 1 Mbps rejeté par pattern.

### ### 5.2 Politique firewall « client isolé » (le scénario AdMel)

Source IP spécifique → destination ANY, action BLOCK ou filtrage app.  
Modèle exact : politique `QUARANTAINE` → tout bloqué (interne + WAN) (§3.1).

### ### 5.3 Zones (zone\_id)

Toutes les politiques portent une paire `source.zone\_id` / `destination.zone\_id`.  
Zones actives (via zone-matrix + chaînes iptables) : Internal, External, Gateway, Hotspot, VPN, DMZ. Récupérer les id réels depuis une politique existante ou `zone-matrix`.

---

### ## 6. Catalogue DPI (moteur Broadcom tdtls, rule v2.202)

- **2 131 applications** avec IDs `cat,app` — correspondance directe avec la syntaxe dataplane `iptables -m dpi32 --cat-app <cat,app>`.
- Fichier exporté : `/root/lab/network/inventory/dpi-app-catalog-udm.txt` (source UDM : `/usr/share/dpi/tdts/bwdpi.app.db`).
- IDs notables : **WhatsApp 0,41** · Telegram 0,40 · Facebook 24,3 · Messenger 0,127 · YouTube 4,112 · Netflix 4,132 · TikTok 4,248 · Spotify 4,130 · Twitch 4,19 · Telegram Web 13,751 · YouTube Kids 4,303.

### ## 7. Fonctions présentes mais désactivées (interrupteurs, pas verrous)

| Fonction        | Preuve                                                                                                           | État             |
|-----------------|------------------------------------------------------------------------------------------------------------------|------------------|
| SSL Inspection  | `versionDetail.services/sslInspection = 3` ; code udapi complet   `services.idslps.sslInspectionEnabled = false` |                  |
| ARP inspection  | `services.arpInspection`                                                                                         | `enabled: false` |
| GeoIP filtering | GeoLite2 présente, `services/geoipFiltering = 2`, chaînes `UBIOS_IN/OUT_GEOIP`                                   | disponible       |
| SNMP            | `snmpd` binaire présent   <b>non lancé</b> , bindé localhost — limite plateforme                                 |                  |

### ## 8. Ce qui N'existe PAS (limites 10.6.101)

- Webhooks sortants réseau (polling externe uniquement)
- API d'historique alarmes/événements (supprimée ; logs via unifi-core)
- Octets/heure/client dans `stat/report/hourly.user`
- SNMP exposé au réseau
- Règles déclenchées nativement par volume de données (l'orchestrateur quota doit être externe — rôle du harnais Hermes)

### ## 9. Erreurs et pièges (retours d'expérience)

| Erreur           | Cause                            | Solution                               |
|------------------|----------------------------------|----------------------------------------|
| 401 Unauthorized | token console sur /proxy/network | utiliser `X-API-Key` ou session + csrf |

| 400 InvalidObject | endpoint v1 settings (`setting/dpi`, `rest/hotspotconf` ...) | passer par v2 / state udapi |  
| 400 NotNull.schedule | POST firewall-policy sans `schedule` | ajouter `{ "mode": "ALWAYS", ... }` |  
| 400 ...RespondTrafficPolicyNotAllowed | `create\_allow\_respond: true` sur BLOCK | mettre `false` |  
| 400 InvalidPayload qos | `qos\_rate\_max\_up: 1` | min 2 Mbps (pattern API) |  
| 404 firewallpolicy | nom singulier inexistant | `firewall-policies` (pluriel + trait) |  
| 405 traffic-flows GET | méthode | POST |  
| zone-matrix HTML au 2e appel | endpoint capricieux | 1 lecture par session |

## ## 10. Sécurité et règles d'usage

- **Lecture** (`GET`, `stat`) : autonomie lab.
- **Écriture** (`POST/PUT/DELETE`, `cmd`, `blocked`, `usergroup`) : catégorie CHANGE — impact + backup + rollback + accord explicite d'AdMel, un go = un palier.
- Backup de référence avant toute écriture : dump complet `firewall-policies`  
→ `/root/lab/network/backups/firewall-policies-full-YYYYMMDD-HHMM.json`.
- Cible de test : uniquement IP du VLAN 22 (lab), jamais les VLANs clients.
- Aucun secret dans ce document ni dans Telegram (clés dans `/root/.hermes/credentials/`, mode 600).
- `rest/setting` expose `x\_password` SMTP en clair → rotation recommandée (F6).

## ## 11. Sources

- Tests API réels 22/09/2026 (X-API-Key) : §3, §4, §5, erreurs §9
- Test d'écriture 22/09 (POST 201 + DELETE 204, rollback vérifié contre backup)
- SSH root 22/09 : `iptables-save` (758 règles), `bwdpi.app.db`, state udapi, `mongo ace/ace\_audit`
- Relevés 24-25/08 : `automation-research.md` (stat/sta, usergroup, vouchers)